

Security+ 2.3 · Race Conditions

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 2.3 — Race Conditions (4:58)** · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: A race condition occurs when two or more processes attempt to modify the same resource simultaneously, and the outcome depends on the order of execution. TOCTOU (Time-of-Check to Time-of-Use) is a specific type where a permission check occurs at one time, but the resource is used later, creating an exploitable gap. Defenses include atomic operations and locking mechanisms.

High-Yield Core Concepts Tested on Exam

- Race condition: outcome depends on the order of execution
- TOCTOU: gap between checking permission and using the resource
- Exploitable when resource state changes between check and use
- Defense: atomic operations, locking, proper synchronization

Exam Tips & Classic Scenarios

- 'checks permission at time A but executes at time B' = TOCTOU
- 'two processes modify same resource simultaneously' = race condition

Typical Exam Scenario: A file is swapped between the permission check and its actual use, allowing an attacker to bypass access controls (TOCTOU/race condition).

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 2.3 — Race Conditions)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **Principle of Least Privilege:** Users and computational entities must be granted only the minimum permissions strictly required to perform designated tasks.
- **Defense-in-Depth (Layered Security):** Application of multiple security controls (technical, administrative, physical) to prevent single-point perimeter compromise.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. Corporate scenario (Race Conditions): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'Race condition: result depends on execution order'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: Race condition: result depends on execution order.
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

2. Corporate scenario (Race Conditions): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'TOCTOU: gap between checking permission and using the resource'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: TOCTOU: gap between checking permission and using the resource...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

3. Corporate scenario (Race Conditions): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'checks permission at time A but executes at time B' = TOCTOU. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: 'checks permission at time A but executes at time B' = TOCTOU...
- D)** Allow shared access among administrators using generic credentials

4. Corporate scenario (Race Conditions): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'Scenario: file is swapped between permission check and use' = TOCTOU/race condition. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: Scenario: 'file is swapped between permission check and use' = TOCTOU...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

5. Corporate scenario (Race Conditions): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'Race condition: result depends on execution order.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: Race condition: result depends on execution order...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

6. Corporate scenario (Race Conditions): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'TOCTOU: gap between checking permission and using the resource'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: TOCTOU: gap between checking permission and using the resource...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

7. Corporate scenario (Race Conditions): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'checks permission at time A but executes at time B' = TOCTOU. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'checks permission at time A but executes at time B' = TOCTOU...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

8. Corporate scenario (Race Conditions): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'Scenario: 'file is swapped between permission check and use' = TOCTOU/race condition.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: Scenario: 'file is swapped between permission check and use' = TOCTOU...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

9. Corporate scenario (Race Conditions): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'Race condition: result depends on the order of execution.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: Race condition: result depends on the order of execution...

10. Corporate scenario (Race Conditions): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'TOCTOU: gap between checking permission and using the resource'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: TOCTOU: gap between checking permission and using the resource...

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) A — Implement the corresponding solution: Race condition: result depends on execution order..

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Race Conditions): Race condition: result depends on execution order. A race condition occurs when the outcome of a process depends on the sequence or timing of uncontrollable events, such as concurrent threads accessing shared resources. Attackers can exploit this to bypass security checks or cause system instability. Mitigation includes proper synchronization, locking mechanisms, and atomic operations.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

2) A — Implement the corresponding solution: TOCTOU: gap between checking permission and using the resource....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Race Conditions): TOCTOU: gap between checking permission and using the resource. Time-of-Check to Time-of-Use (TOCTOU) is a type of race condition where a program checks a condition (e.g., file permissions) and then uses the resource, but the state can change between the check and the use. An attacker can exploit this gap to bypass security controls, such as by replacing a file with a malicious one after the check but before use. Mitigations include using atomic operations, file locking, and avoiding predictable resource names.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

3) C — Implement the corresponding solution: 'checks permission at time A but executes at time B' = TOCTOU....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Race Conditions): 'checks permission at time A but executes at time B' = TOCTOU.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting

pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).

- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

4) A — Implement the corresponding solution: Scenario: 'file is swapped between permission check and use' = TOCTOU....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Race Conditions): Scenario: 'file is swapped between permission check and use' = TOCTOU/race condition. A Time-of-Check to Time-of-Use (TOCTOU) race condition occurs when a program checks a condition (e.g., file permissions) and then uses the resource, but the resource is altered between the check and use, leading to a security bypass. This is a classic vulnerability in concurrent systems. Security+ highlights the need for atomic operations, proper locking, and secure coding practices to prevent such race conditions.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaches compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* This destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

5) B — Implement the corresponding solution: Race condition: result depends on execution order....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Race Conditions): Race condition: result depends on execution order. A race condition is a software vulnerability where the outcome depends on the timing or sequence of concurrent operations, potentially allowing an attacker to manipulate the system state. The appropriate control is to implement proper synchronization mechanisms (e.g., locks, atomic operations) and secure coding practices to prevent exploitation.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

6) A — Implement the corresponding solution: TOCTOU: gap between checking permission and using the resource....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Race Conditions): TOCTOU: gap between checking permission and using the resource.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

7) B — Implement the corresponding solution: 'checks permission at time A but executes at time B' = TOCTOU....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Race Conditions): 'checks permission at time A but executes at time B' = TOCTOU. This describes a Time-of-Check to Time-of-Use (TOCTOU) race condition, where a permission check occurs at one point in time but the resource is used later, allowing an attacker to exploit the gap between check and use. The recommended control is to implement proper synchronization mechanisms, such as file locking, atomic operations, or re-validating permissions immediately before use, to eliminate the race window.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

8) B — Implement the corresponding solution: Scenario: 'file is swapped between permission check and use' = TOCTOU....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Race Conditions): A Time-of-Check to Time-of-Use (TOCTOU) race condition occurs when a file or resource is swapped between the permission check and its actual use, allowing an attacker to exploit the timing gap.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.

- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

9) D — Implement the corresponding solution: Race condition: result depends on the order of execution....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Race Conditions): Race condition: result depends on the order of execution. A race condition occurs when the outcome of a process depends on the sequence or timing of uncontrollable events, such as the order in which concurrent threads execute, potentially leading to security vulnerabilities like time-of-check to time-of-use (TOCTOU) flaws.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

10) D — Implement the corresponding solution: TOCTOU: gap between checking permission and using the resource....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Race Conditions): TOCTOU: gap between checking permission and using the resource. TOCTOU (Time-of-Check to Time-of-Use) is a class of race condition where the state of a resource changes between the time it is checked and the time it is used, allowing an attacker to exploit the gap. Mitigation involves using atomic operations, file locking, or proper synchronization to ensure the check and use are performed atomically. This is a preventive technical control that addresses the vulnerability.

✗ **Why the other options are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials*: This destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

